

Máster en Ciberseguridad Defensiva y Ofensiva

Universidad Complutense de Madrid — NTIC Master

Arquitectura de seguridad de referencia para agentes LLM con acceso a herramientas

Modelado de amenazas con MITRE ATLAS y validación experimental en laboratorio

Trabajo Fin de Máster

Rodrigo Hernández

Tutores: Javier Domínguez Gómez y Román Ramírez

Curso 2025–2026 — Convocatoria de febrero de 2027

Resumen

Los agentes basados en grandes modelos de lenguaje (LLM) con acceso a herramientas amplían la superficie de ataque clásica del *prompt injection* hacia la ejecución de acciones: consulta de datos, navegación web, envío de correo y uso de credenciales. Este trabajo propone una **arquitectura de seguridad de referencia** para este tipo de agentes, construida a partir de un modelado de amenazas (PASTA + STRIDE) mapeado a MITRE ATLAS y a OWASP AGENTIC SECURITY TOP 10 2026, y la **valida experimentalmente** en un laboratorio local y de coste cero. Se somete a un agente objetivo a cuatro escenarios de ataque bajo tres configuraciones de control y se mide la tasa de éxito de ataque (ASR) mediante detección determinista por canarios, junto con la tasa de bloqueo de tareas legítimas y la latencia. Los resultados cuantifican la reducción de riesgo aportada por cada control y se sintetizan en un plano de gobierno alineado con el marco regulatorio aplicable.

Palabras clave: seguridad de IA, agentes LLM, prompt injection, MITRE ATLAS, OWASP ASI, modelado de amenazas, red teaming.

Índice

1. Introducción, motivación y objetivos 2

1.1. Objetivos 2

1.2. Alcance y contribuciones 2

2. Estado del arte 2

2.1. Taxonomías de amenazas 2

2.2. Herramientas de evaluación de seguridad de LLM 2

2.3. Guardrails y controles conocidos 2

3. Metodología 2

3.1. Métricas 2

4. Sistema objetivo y modelo de amenazas 3

5. Diseño del laboratorio experimental 3

6. Escenarios de ataque y resultados de línea base 3

7. Arquitectura de seguridad de referencia 3

8. Validación experimental y análisis comparativo 3

9. Plano de gobierno y cumplimiento normativo 3

10. Conclusiones, limitaciones y trabajo futuro 3

A. Repositorio y guía de despliegue 3

B. Corpus de ataques 4

C. Reglas de detección y evidencias 4

1. Introducción, motivación y objetivos

1.1. Objetivos

- O1: modelar las amenazas de un agente LLM con herramientas y priorizarlas con ATLAS/OWASP ASI.
- O2: diseñar una arquitectura de seguridad de referencia con controles concretos y justificados.
- O3: validar experimentalmente su eficacia (ASR) frente a una línea base sin controles.
- O4: derivar un plano de gobierno y cumplimiento accionable.

1.2. Alcance y contribuciones

2. Estado del arte

2.1. Taxonomías de amenazas

El marco MITRE ATLAS [1] cataloga tácticas y técnicas adversarias contra sistemas de IA; el *OWASP Top 10 for Agentic Applications 2026* [2] las traslada al plano de los agentes (ASI01–ASI10). Las guías de ENISA [3] aportan el encuadre regulatorio europeo, y la CSA [4] documenta el envenenamiento de herramientas en el protocolo MCP.

2.2. Herramientas de evaluación de seguridad de LLM

Se comparan **garak** [5] (escáner de vulnerabilidades) y **promptfoo** [6] (evaluación y red teaming), que en este trabajo actúa como segunda fuente de medida independiente del harness propio.

2.3. Guardrails y controles conocidos

Como guardrail de entrada se emplea *Llama Prompt Guard 2* [7], un clasificador ligero que se ejecuta en CPU.

3. Metodología

3.1. Métricas

La métrica principal es la *Attack Success Rate* (ASR):

$$\text{ASR} = \frac{\#\{\text{intentos en los que un canario objetivo alcanza un sumidero}\}}{\#\text{intentos}}.$$

Se acompaña de la tasa de bloqueo de tareas legítimas (falsos positivos sobre 50 tareas benignas) y la latencia.

[Figura: diagrama de flujo de datos con límites de confianza — exportar
docs/threat-model/dfd.mmd]

Figura 1: Diagrama de flujo de datos del agente y sus límites de confianza.

Tabla 1: Matriz de amenazas priorizada (extracto).

ID	STRIDE	ATLAS	ASI	Control principal
T1	Tampering/EoP	AML.T0051	ASI01	Guardrail de entrada
T2	Tampering	AML.T0051	ASI01/06	Guardrail sobre resultados de herramientas
T3	Spoofing	AML.T0099	ASI04	Pinning de manifiesto de herramientas
T4	Info. disclosure	AML.T0055	ASI03	Broker de credenciales + mínimo privilegio
T5	Info. disclosure	AML.T0055	ASI03	Allowlist de egress + filtro de salida

4. Sistema objetivo y modelo de amenazas
5. Diseño del laboratorio experimental
6. Escenarios de ataque y resultados de línea base
7. Arquitectura de seguridad de referencia
8. Validación experimental y análisis comparativo
9. Plano de gobierno y cumplimiento normativo
10. Conclusiones, limitaciones y trabajo futuro

Referencias

- [1] MITRE. MITRE ATLAS: Adversarial threat landscape for ai systems, 2026.
- [2] OWASP Agentic Security Initiative. Owasp top 10 for agentic applications 2026, 2026.
- [3] ENISA. Guidelines on securing ai systems, 2026.
- [4] Cloud Security Alliance. Tool poisoning and the MCP attack surface, 2026.
- [5] NVIDIA. garak: Llm vulnerability scanner, 2026.
- [6] promptfoo. promptfoo: Llm eval and red teaming, 2026.
- [7] Meta AI. Llama prompt guard 2, 2025.

A. Repositorio y guía de despliegue

Código fuente y reproducibilidad: <https://github.com/<usuario>/tfm-agent-security>.

Tabla 2: ASR (%) por escenario y configuración (rellenar con `results/asr.csv`).

Escenario	C0	C1	C2
S1 — inyección directa			
S2 — inyección indirecta			
S3 — herramienta envenenada			
S4 — robo de credenciales			
Global			

[Figura: ASR por escenario y configuración — `results/asr.png`]

Figura 2: Tasa de éxito de ataque por escenario y configuración.

B. Corpus de ataques

Semillas y mutadores; muestra de variantes por escenario.

C. Reglas de detección y evidencias

Telemetría estructurada y ejemplos de captura del sumidero de egress.